Microsoft

Maturity Model for Microsoft 365 Practitioners

October 2026

Modern Compliance in Microsoft 365: A Maturity Model Perspective



✨ **Guest star** ✨ Joanne Klein

Current Core Team

Marc Anderson	Sympraxis Consulting | @sympmarc
Simon Doy	iThink 365 | @simondoy (.bsky.social)
Simon Hudson	Novia Works | @simonjhudson (.bsky.social)
Sharon Weaver	Smarter Consulting | @sharoneweaver
Pia Langenkrans	Cloud 476 | @zellery_se
Mats Warnolf	Mats Warnolf AB | @MatsWarnolf

Emeriti

Emily Mancini, Left Uncharted | @eemancini

Initiative started by Sadie [Van Buren] Gilronan as the SharePoint Maturity Model in 2010

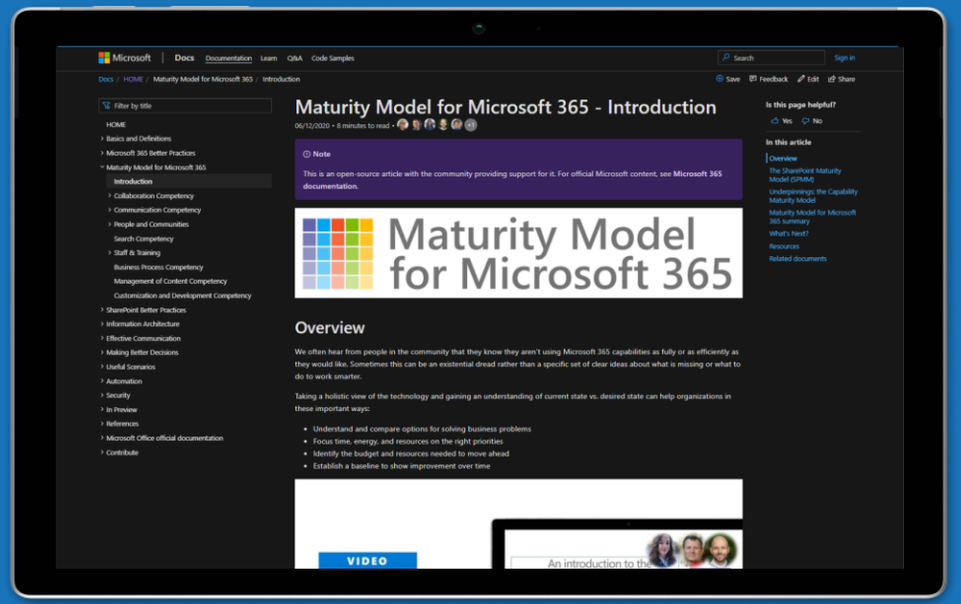
Agenda

Practitioner & Maturity Model overview

- Artifacts and Updates
- Purpose

Contribute

The main event



https://symp.info/MM4M365



Reminders

Join us every month!

Download the recurring calendar series

https://aka.ms/mm4m365/ics

New link, same destination

Global Microsoft 365 & Power Platform Meetup

https://www.meetup.com/global-microsoft-365-dev-meetup/events/

MM4M365 - Purpose and articles

PURPOSE

- Improve organization through use of technology
- Benchmark company and department
- Select appropriate approach
- Develop an organizational business and technical roadmap based on:
  - What's possible
  - What's desired
  - Organization's culture and drivers
- Lead and support strategic planning, with senior management
- Align implementation needs and objectives
- Discuss use of the platform with IT – not just technology
- Socialization tool

https://symp.info/MM4M365

Artifacts

Published competencies

- AI & Cognitive Business ✨
- Business Process ✨
- Collaboration ✨
- Communication ✨
- Customization & Development ✨
- Employee Experience ✨
- Governance, Risk & Compliance ✨
- Infrastructure ✨
- Management of Content ✨
- People & Communities
- Search ✨
- Security
- Staff & Training

✨ = Key actions highlighted

How to elevate...

- Collaboration
- Communication
- People & Communities
- Staff & Training
- Governance, Risk and Compliance
- Security

Practical Scenarios

- Microsoft 365 Service Change Management
- Servicing Microsoft 365 Apps
- Servicing Health Management
- Enhancing Brand Management
- Knowledge Management

Supporting articles

- Search
- Communication

Tools

- Running a MM4M365 workshop
- Practitioner meeting recordings

In progress competencies

- Data & Analytics

Artefacts, structure, and scope

The Maturity Model

- Competencies
- Principles
- How to elevate…
- Practical scenarios

Competencies

- Overview etc.
- Evolution
  - Characteristics grouped by sub-competency
  - Level 100-500
- Scenarios, Costs & Benefit, Conclusion
- Microsoft 365 Toolsets
- Resources & contributors

Sub-competencies

- Group characteristics into common categories
- Some consistency across competencies

Characteristics

- Grouped by Level
- Grouped by sub-competency
  - Sparkled
  - Unsparkled

Business capability (Competency)

Business activities (Scenarios)

Technologies (Microsoft 365 Toolsets)

Business Functions

Markets

MM4M365 provides benchmarks to measure your organization

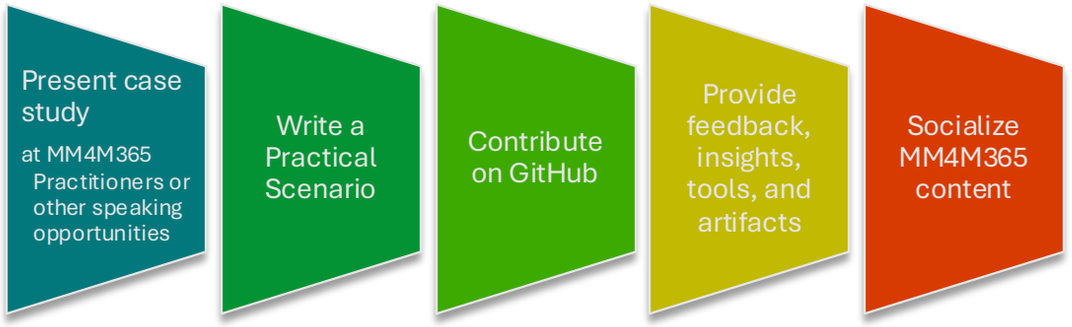
Maturity Level	Description/characteristics	Intent
Level 500 Optimizing	Optimal, systematic, statistical, improvement-focus, automated, assured, proactive	“We want to ensure all the key processes are always effective and resilient, while designing the same into anything new we do”
Level 400 Predictable	Productive, interactive, responsive, enhanced, effective, adaptable, quality	“Let’s make things even better by measuring, analyzing and taking actions to improve based on that“
Level 300 Defined	Documented, policy-driven, planned, controlled, stable	“We have defined our processes, policies and procedures, everyone seems to be doing the right thing; let’s keep doing that”
Level 200 Managed	Routine, legacy, fire-fighting, variable, personally managed	“We should ensure everyone knows what they should be doing”
Level 100 Initial	Ad hoc, reactive, uncontrolled, chaotic, unstable, not designed	“Let’s keep putting the fires out and keep the lights on!”

Overview

Practitioners for Maturity Model for Microsoft 365

Get Involved

https://symp.info/SiCCommunityContentGuide



Run a MM4M365 workshop

- https://symp.info/MM4M365Workshop

Purpose

Safe space to:

- Share & test your thoughts
- Guide the process and content
- Decide how to promote your use of the Maturity Model
- Hone your pitch

Discussion-based monthly meeting

- Understand the competencies & measuring maturity
- Awareness of new assets
- Feedback on the maturity model
- Share anecdotes and success stories
- Map technology, maturity level & competencies
- Run workshops

Upcoming topics in 2026

January 20	February 17	March 17	April 21	May 19	June 16
Maturity Model for Microsoft 365 Agent	MM4M365 AMA	Security Competency	Revisiting the Staff and Training Competency	Frontier Firm: Maturity Model Perspective	Revisit the People and Communities Competency
⭐ Simon Doy ⭐	⭐ Everyone ⭐	⭐ Mats Warnolf ⭐ ⭐ Clement Betacorne ⭐	⭐ Emily Mancini ⭐	⭐ Merethe Stave ⭐	⭐ Tracy van der Schyff ⭐

July 21	August 18	September 15	October 20	November 17	December 15
Summer break	*Summer break*	Revisiting the Governance, Risk, and Compliance Competency	Modern Compliance in Microsoft 365: A Maturity Model Perspective	AI at Work: MM4M365	*Winter break*
None	None	⭐ Nikki Chapple ⭐	⭐ Joanne Klein ⭐	⭐ Core Team ⭐	None

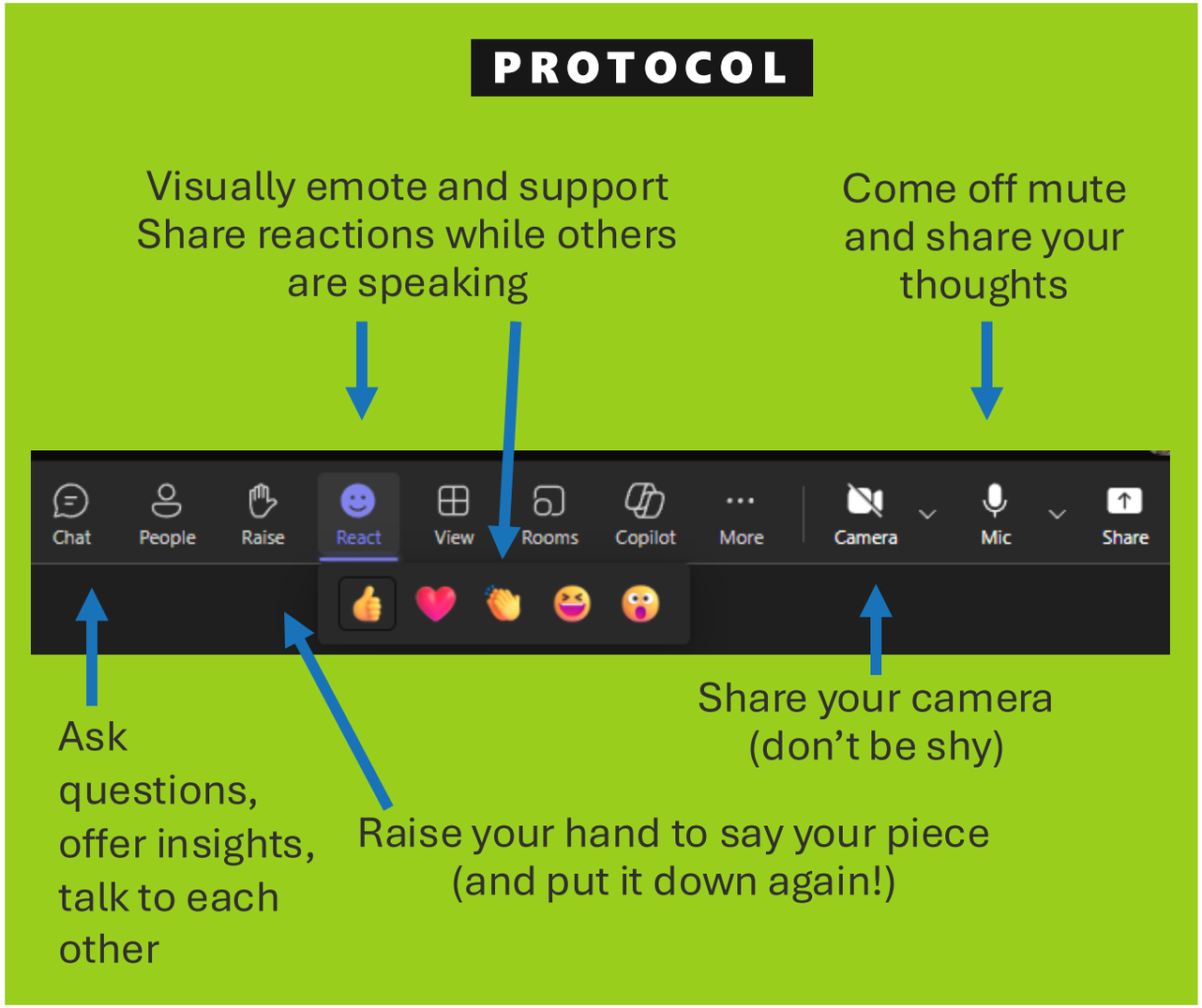
Upcoming topics in 2027 – Upcoming!

January 19	February 16	March 16	April 20	May 18	June 15
TBD	TBD	TBD	TBD	TBD	TBD
⭐ You? ⭐	⭐ You? ⭐	⭐ You? ⭐	⭐ You? ⭐	⭐ You? ⭐	⭐ You? ⭐

July 20	August 17	September 21	October 19	November 16	December 21
Summer break	*Summer break*	TBD	TBD	TBD	*Winter break*
None	None	⭐ You? ⭐	⭐ You? ⭐	⭐ You? ⭐	None

The Main Event

Modern Compliance in Microsoft 365: A Maturity Model Perspective



The Proposed Modern GRC Competency

BUSINESS REQUIREMENT

Share sensitive information with an external partner

GRC DEFINES THE DESIRED OUTCOME

Enable external collaboration while protecting sensitive information

1. WHO?	2. WHAT COULD GO WRONG?	3. WHAT MUST WE DO?	4. HOW DO WE KNOW?
Governance & Accountability	**Risk Management**	**Obligations, Policy & Compliance**	**Evidence & Assurance**
Accountability for the outcome	Risks and acceptable residual risk	Requirements and control objectives	Evidence the outcome is being achieved

Evidence and insight drive adaptation

AI and agents cut across all four. They are not a fifth GRC capability.

Who owns what?

GRC

Defines the outcome and guardrails

Defines evidence expectations

Evaluates effectiveness and residual risk

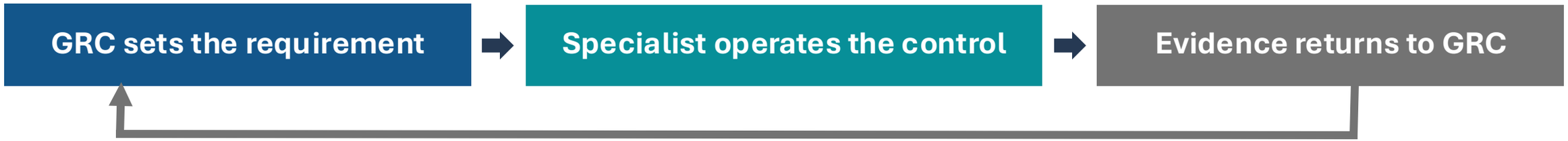
Specialist competencies

Designs, implements and operates controls

Produces operational evidence

Demonstrates performance and improves controls

⚠ *GRC provides second-line assurance. Independent Internal Audit remains separate.*



One GRC Outcome Across the Four Capabilities

Desired GRC outcome

"Enable external collaboration while protecting sensitive information"

Governance & Accountability

WHO?

- Who owns the information?
- Who owns the workspace?
- Who sponsors the external party?
- Who approves exceptions?

Risk Management

WHAT COULD GO WRONG?

- What sensitive information is present?
- Who can access it?
- Which sharing paths create exposure?
- What residual risk remains?

Obligations, Policy & Compliance

WHAT MUST WE DO?

- What classification applies?
- What sharing restrictions apply?
- How long must it be retained?
- What access reviews are required?

Evidence & Assurance

HOW DO WE KNOW?

- Can appropriate access be shown?
- Did protection and DLP apply and operate?
- Were exceptions approved?
- Was inappropriate sharing remediated?

The value of GRC is not that it configures all these controls. It keeps them connected to one outcome.

How specialists deliver the outcome

Desired GRC outcome

"Enable external collaboration while protecting sensitive information"

01 Design

- Define what is sensitive for your org.
- Define access rules for sensitive files.
- Define location sensitivity and access controls

02 Implement

- Configure sensitivity labels and access settings.
- Configure policies for users.
- Configure policies for locations.
- Staff training

03 Operationalize

- Manage guest access
- Apply sensitivity labels on sensitive information and locations.
- Triage alerts.

04 Monitor & improve

- Review evidence and tune controls.
- Check for configuration drift and correct as required
- Retest as the service changes

These activities can involve several specialist competencies working together.

Specialist Competency Maturity Describes How Controls Operate

Not how many technologies have been deployed

100
INITIAL

WE REACT

Inconsistent, manual and issue-driven

200
MANAGED

WE ACTIVELY MANAGE

Owners and repeatable activities emerge

300
DEFINED

WE OPERATE CONSISTENTLY

Standards, procedures and configurations are documented; drift is monitored

400
PREDICTABLE

WE KNOW IT WORKS

Operation and outcomes are measured and evidenced

500
OPTIMIZING

WE LEARN AND ADAPT

Evidence and findings drive control improvement

Specialist Competencies apply the same maturity level approach as the four GRC capabilities where EACH specialist competency is assessed independently.

The maturity question is not “What did we deploy?”, it is “How reliably does the control achieve its outcome?”

Configured Does Not Necessarily Mean Effective

Three levels of evidence provide progressively stronger assurance

1 CONFIGURATION EVIDENCE

WAS THE CONTROL ESTABLISHED?

Examples:

- Sensitivity label taxonomy
- Policy configuration
- Role assignment
- Retention settings (File plan)
- DLP rule
- Conditional Access policy

2 OPERATING EVIDENCE

DID THE CONTROL ACTUALLY RUN?

Examples:

- Published/auto-applied labels
- Policy match
- Access-review decision
- Blocked/warned alert and action
- Disposition review
- Record of corrective action

3 OUTCOME EVIDENCE

DID IT ACHIEVE ITS PURPOSE?

Examples:

- Reduced exposure
- Fewer unmanaged exceptions
- Timely remediation
- Appropriate access maintained
- Risk within appetite

Configuration tells us a control exists. Operating and outcome evidence tell us whether it works.

Specialist Competencies for GRC competency

Specialist competency	Microsoft technology areas/controls that support GRC outcomes
Staff & Training	Includes technical controls (Terms of Use, DLP policy tips, label hover definitions, “Learn more” links to internal governance sites) as well as more traditional training channels via Viva Learning, Lunch and Learns, etc.
Identity implementation	**Microsoft Entra ID**: Conditional Access, MFA. **Entra ID Protection**: identity risks - risk-based access. **Entra ID Governance**: Privileged identities, access reviews, access packages and lifecycle workflows.
Information protection	**Microsoft Purview Information Protection**: classifiers, container and file labels, encryption. **Purview Data Loss Prevention**: prevent accidental/unauthorized sharing of sensitive data (including AI). **Purview Insider Risk Management**: detect risky data handling, risky users (including AI). **Purview Communication Compliance**: detect risky/non-compliant communications (including AI). **Purview Audit**: activity monitoring (including AI).
Retention configuration	**Microsoft Purview Data Lifecycle Management**: retention policies, labels and adaptive scopes. **Purview Records Management**: records, event-based retention and disposition review.
AI and Cognitive Business	**Microsoft Agent 365**: agent registry and governance. **Microsoft Entra Agent ID**: agent identity and access. **Microsoft Copilot Studio / Power Platform**: data policies and connector restrictions. **Microsoft Purview DSPM**: AI data risks.
Search and grounding	**SharePoint Advanced Management**: access governance, Restricted Access Control, Restricted Content Discovery. **Microsoft Purview DSPM**: Data risk assessments. **SharePoint / OneDrive**: permissions and sharing controls. **Microsoft 365 Copilot connectors**: external sources and access permissions.
Security operations	**Microsoft Defender XDR**: threat detection and response across endpoints, identities, email and cloud apps. **Microsoft Sentinel**: security alerts, hunting and response automation. **Microsoft Intune**: endpoint security, device compliance and app protection.

One Technology. Multiple Governance Contributions.

Organize around governance outcomes, **not** product boundaries

Start with the governance outcome you want to achieve…

Microsoft Purview solutions

Our organization wants to achieve these outcomes:

Data visibility & classification • Clear data ownership • Trusted data quality
Sensitive-data protection • Reduced data loss • Insider-risk reduction
Compliant communications • Retention & defensible disposal • Legal readiness
AI data-risk management • Compliance improvement • Audit-ready evidence

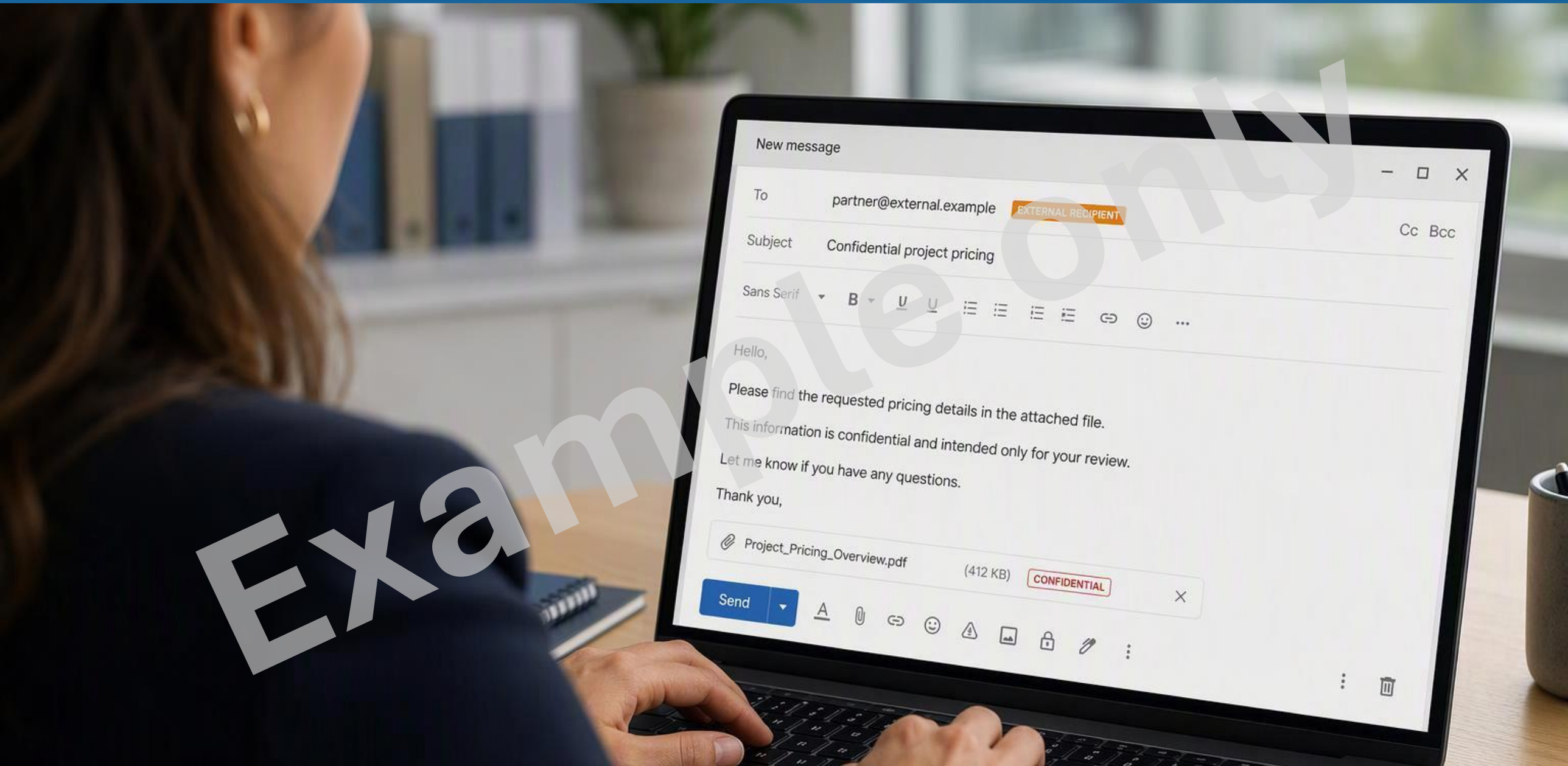
SharePoint Advanced Management features

Our organization wants to achieve these outcomes:

Accountable site ownership • Validated business purpose • Reduced site sprawl
Appropriate access • Reduced oversharing • Controlled external collaboration
Controlled downloads • Safer Copilot discovery • Site lifecycle oversight
Ownership attestations • Access-review evidence • Governance reporting

One Microsoft technology can contribute to many governance outcomes.

Outcome: External collaboration is enabled while protecting sensitive information



Example only

Outcome: External collaboration is enabled while protecting sensitive information

Start with the business outcome, not the product configuration

CONCRETE SCENARIO

ZavaCorp account renewal

An account manager needs to share a renewal package with an external implementation partner.

CONTENT
Pricing, customer IDs, service history

DESTINATION
Partner guest in a SharePoint site

BUSINESS NEED
Valid, time-bound collaboration

GOVERNANCE OUTCOME

- Sensitive information is shared only for a legitimate business purpose.
- The recipient, owner and approval are known.
- Protection follows the information outside the organization.
- Access is reviewed and removed when no longer needed.

EVIDENCE EXPECTATION

- Who approved the sharing?
- What information was shared?
- Which protections were applied?
- Did the control intervene when required?
- Was access reviewed and removed?

Sample evidence in this walkthrough is illustrative.

GRC defines the outcome and evidence expectation. Specialists determine the operational “how.”

1. Establish Accountability and Understand the Risk

GRC Capabilities: Governance & Accountability, Risk Management

SPECIALIST COMPETENCY "HOW"

COLLABORATION

- Assign the site owner and external-party sponsor.
- Require approval before guest access is granted.

MANAGEMENT OF CONTENT

- Identify sensitive information in the package.
- Confirm the business purpose and required retention.
- Ensure package is placed on the appropriate SharePoint site

SECURITY

- Verify external identity and access conditions.
- Define review / expiry expectations.

CONTROL DESIGN

- Site owner: Jordan Lee (Account Manager)
- Guest sponsor: Partner Lead
- Guest access expires after 30 days
- Container sensitivity labels defined
- File sensitivity labels defined
- Sharing limited to named guests
- High-risk files identified
- Risk owner accepts any exception

TECHNOLOGY SUPPORT

Entra access package/access review
SharePoint Advanced Management (SAM) data access governance reports, site access reviews.
Purview data classification.
Purview container & file sensitivity labels

SAMPLE EVIDENCE

OWNER ATTESTATION
Jordan Lee confirmed responsibility for the collaboration site.

GUEST APPROVAL
Partner guest approved by sponsor

RISK FINDING
3 confidential (high risk) files detected

ACCESS CONDITION
Named guest, expiry: 30 days

DECISION
Proceed with treatment controls

Before protecting the information, establish who is accountable and what exposure must be treated.

2. Translate the Outcome into Operating Controls

GRC Capability: Obligations, Policy & Compliance

SPECIALIST COMPETENCY "HOW"

MANAGEMENT OF CONTENT

- Apply a container sensitivity label to SharePoint site
- Apply a sensitivity label that protects the file outside the tenant.
- Apply the appropriate retention requirement.

COLLABORATION

- Restrict sharing to named guests.
- Disable anonymous links for the workspace.

SECURITY + BUSINESS PROCESS

- Require authentication and compliant access.
- Require justified exceptions.

CONTROL OPERATION

1	**Classify**	Customer Id classifier
2	**Label/Protect/ Retain**	Confidential – External (Encryption + named users) Customer Agreement (Retain for 7 years)
3	**Restrict**	No anonymous sharing
4	**Detect**	DLP inspects external share
5	**Respond**	Block or require override

TECHNOLOGY SUPPORT

Purview data classification
Purview sensitivity label & encryption
Purview Data Loss Prevention policy
Purview retention policies & labels
Purview Audit
SharePoint Admin Center sharing settings

SAMPLE EVIDENCE

CLASSIFICATION
Customer Id detected

PROTECTION
Label applied: Confidential – External
Encryption limited to named users

DLP EVENT
External share blocked: customer ID

EXCEPTION
Override approved with justification

RETENTION
Customer agreement: 7 years

Policy intent becomes real only when specialists translate it into enforceable and repeatable controls.

3. Demonstrate the Governance Outcome

GRC Capability: Evidence & Assurance closes the loop

CONFIGURATION

Was the control established?

- Sensitivity label published
- DLP rule enabled
- Retention label published
- Guest access expiry configured

SAMPLE
4 control settings documented

Useful, but not enough.

OPERATION

Did the control run?

- Label applied to package
- DLP detected attempted share
- Retention label applied to package
- Access review completed

SAMPLE
1 block • 1 approved override

Evidence of control activity.

OUTCOME + ASSURANCE

Did it achieve the outcome?

- Only the approved partner retained access.
- The blocked file was not exposed externally.
- The approved file remained protected after sharing.
- Guest access was removed when the engagement ended.
- The file package will be retained for the required duration.

SAMPLE OUTCOME
0 unapproved external recipients

ASSURANCE DECISION
Control effective; no open exception

The strongest evidence connects configuration, operation and outcome back to the original requirement.

Connect Every Requirement to a Control, an Owner and Evidence

A practical recommendation for specialist competencies within the GRC cross-cutting competency

1. Use GRC to define the requirement, outcome and accountability – it is a cross-cutting competency.
2. Use 1:n specialist competencies to contribute to the outcome by designing, implementing and operationalizing the controls.
3. Use Microsoft technologies as control mechanisms, NOT as maturity proxies.
4. Use evidence to challenge effectiveness and drive improvement.

GRC provides the architecture. Specialist competencies make it operational. Evidence ties it back to outcomes.

Thank you

Next MM4M365 monthly call

November 17 – 10 ET / 7 PT

Third Tuesday of every month: https://aka.ms/mm4m365/ics

Stay in touch

- Articles: https://symp.info/MM4M365
- Newsletter: Sign up
- LinkedIn group: Maturity Model for Microsoft 365 Community
- YouTube: http://mmvideos.m365.ms/
- Slide decks: https://symp.info/MM4M365Slides
- Twitter/X: @M365Maturity | @M365CommDocs | #MM4M365
- BlueSky: @mm4m365.org

Take the Maturity Model Self-Assessment

- Fill out the Maturity Model Survey: https://symp.info/MM4M365Survey






MATURITY MODEL
FOR MICROSOFT 365
PnP
Maturity Model
Maturity Model
Maturity Model
PARKER